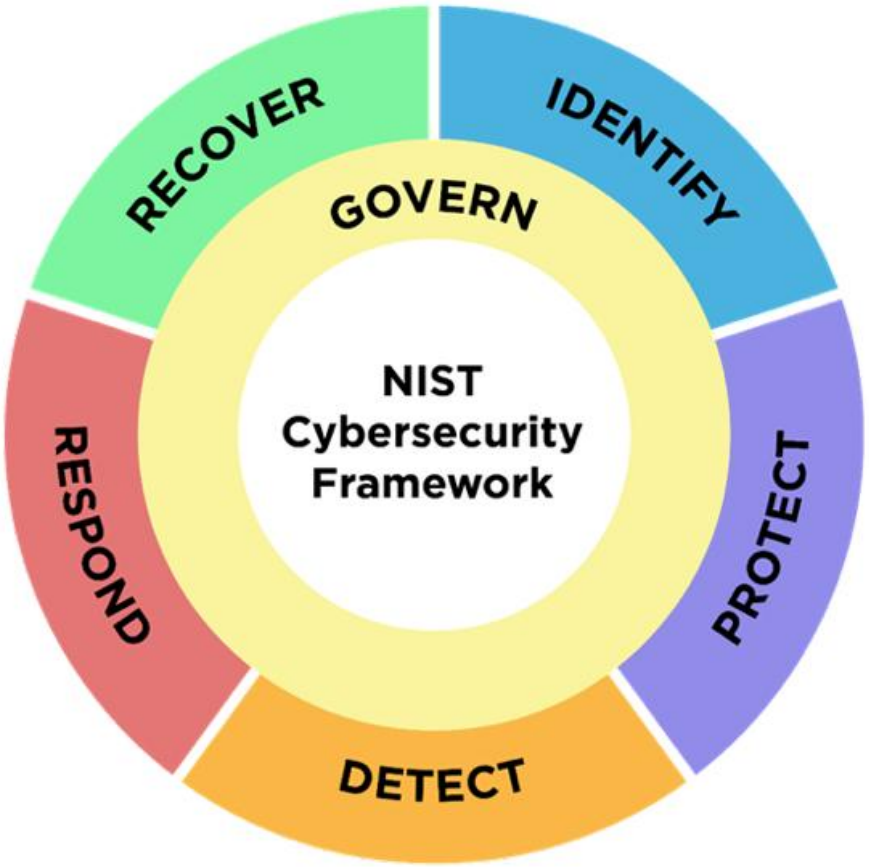
IS 414:
IS SECURITY & CONTROLS

Dr. Taylor Wells

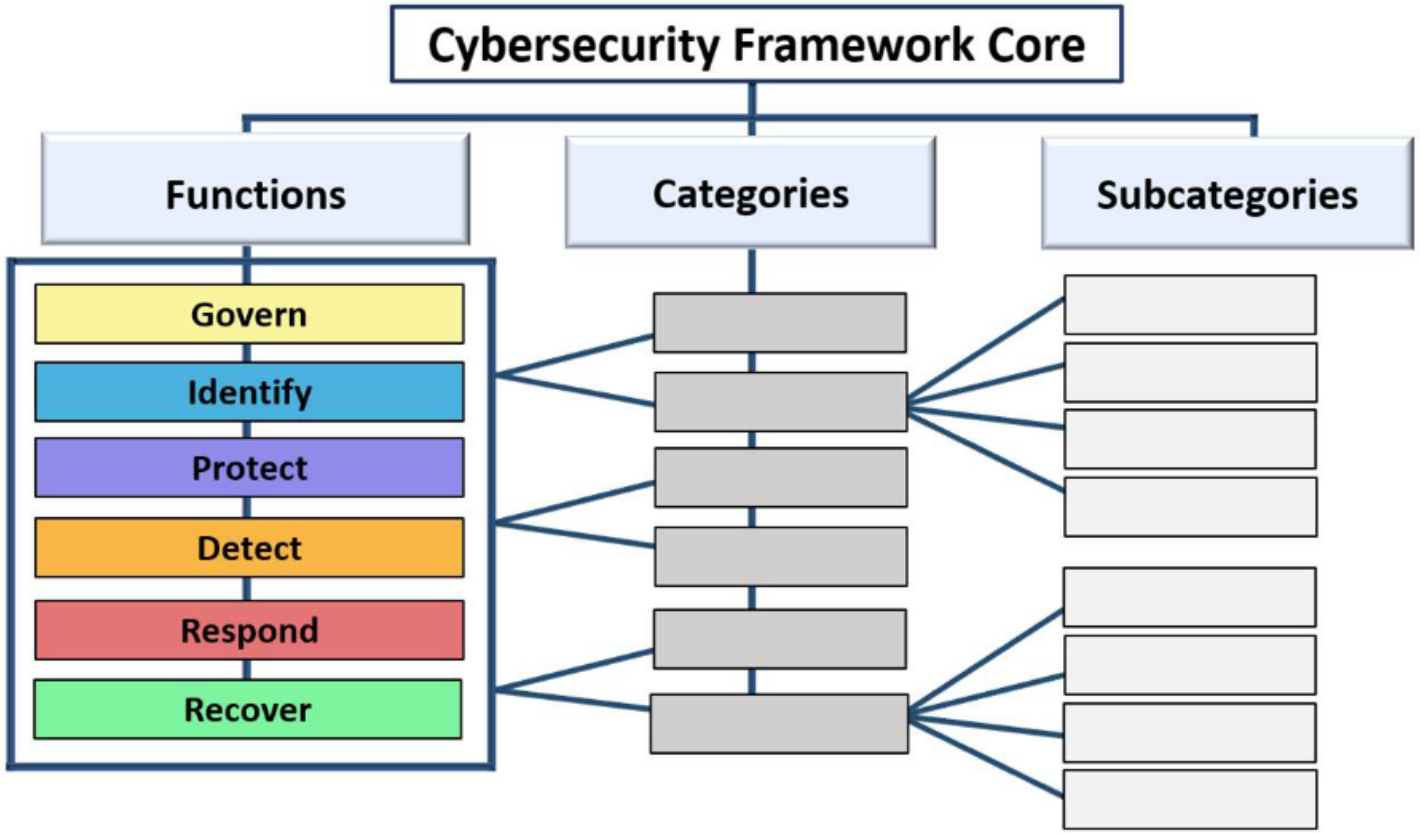
Admin

NIST Cybersecurity Framework 2.0



NIST Cybersecurity Framework 2.0

- 1. Core

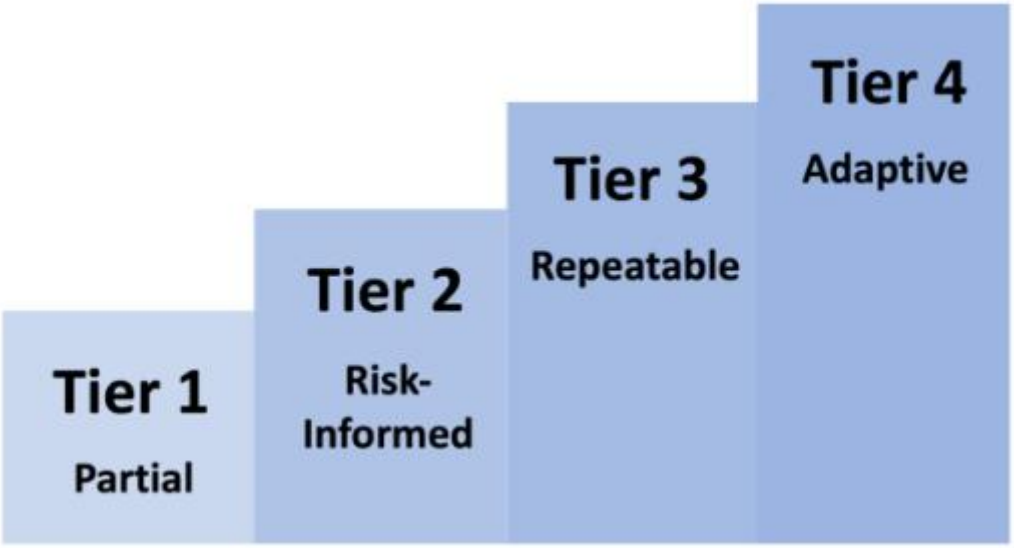


NIST Cybersecurity Framework 2.0

- 2. Profiles
  - https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1301.pdf
  - https://www.nist.gov/document/csf-20-notional-organizational-profile-template

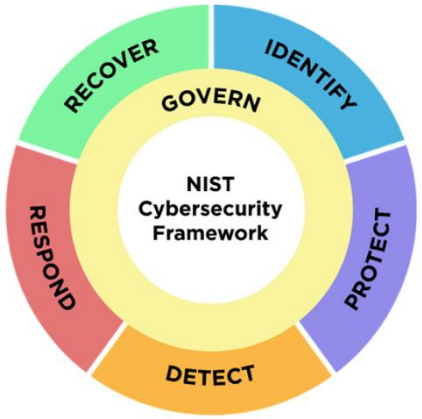
NIST Cybersecurity Framework 2.0

- 3. Tiers
  - https://nvlpubs.nist.gov/nistpubs/SpecialPublications/NIST.SP.1302.pdf



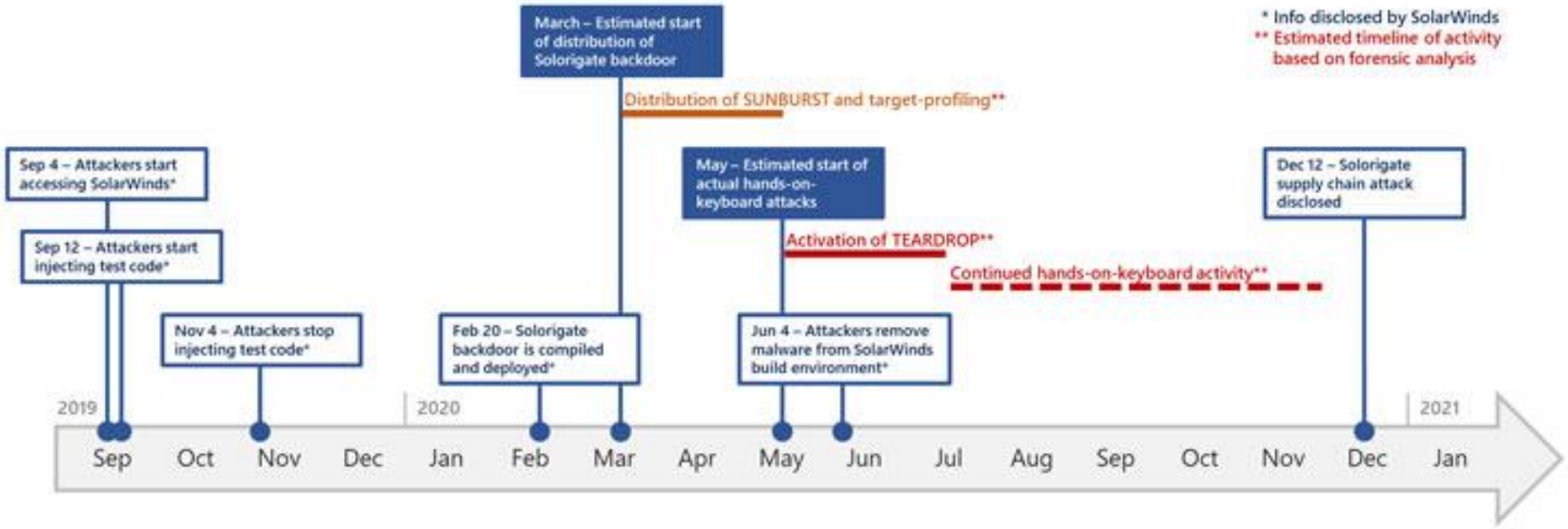
NIST Cybersecurity Framework 2.0

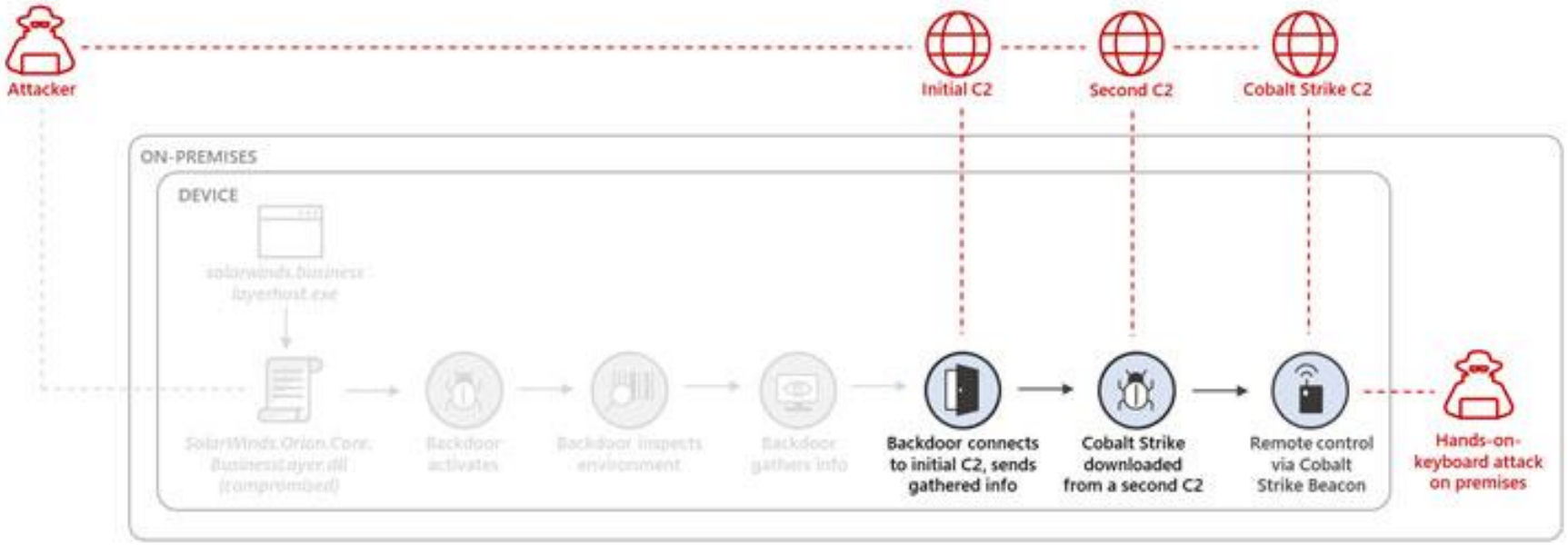
- NIST CFS 2.0 Resource Guide
- NIST CFS 2.0 Implementation Examples



SOLARWINDS ATTACK (SUNBURST HACK)

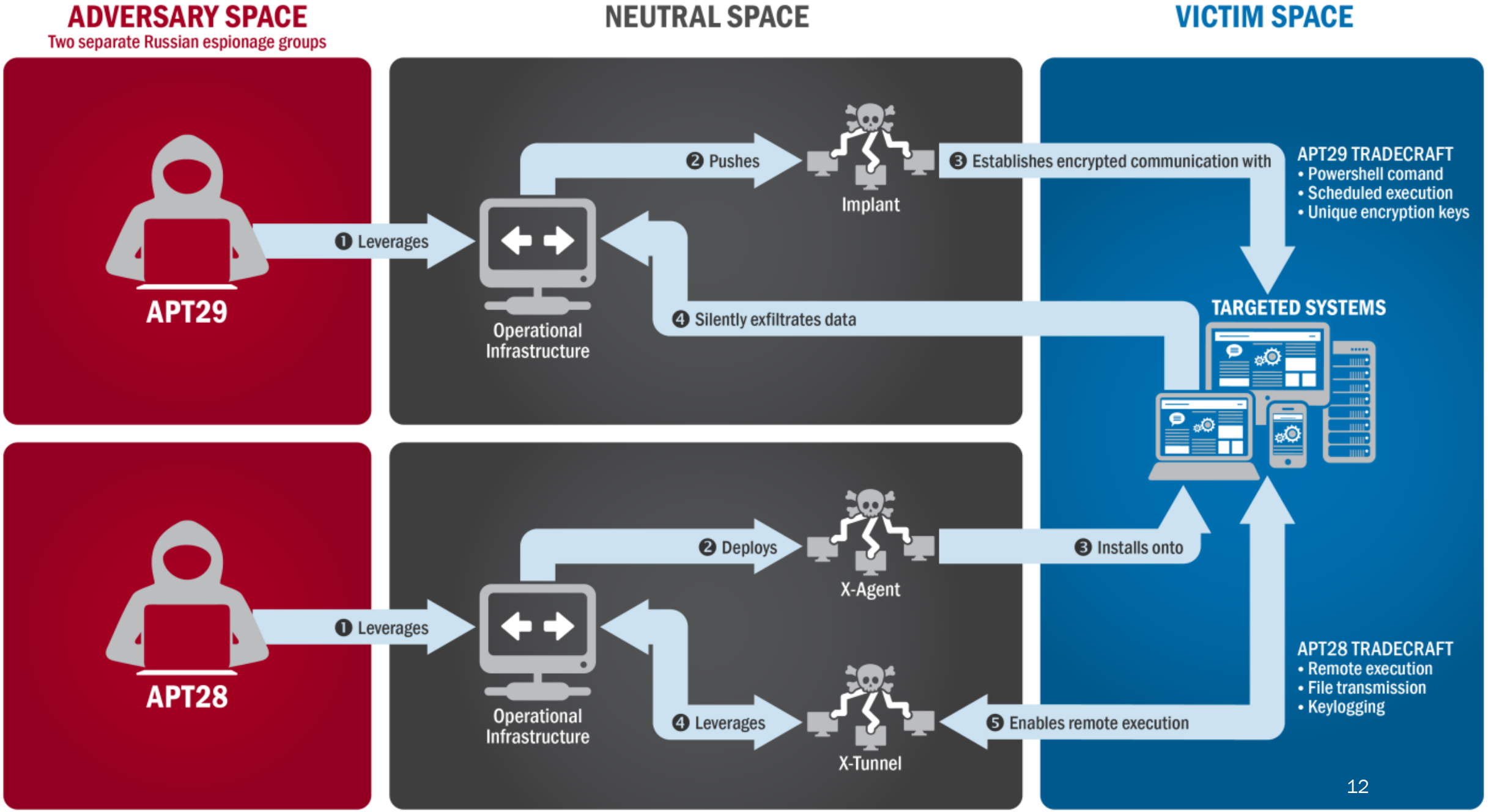
solarwinds


* Info disclosed by SolarWinds
** Estimated timeline of activity based on forensic analysis
March – Estimated start of distribution of Solorigate backdoor
Distribution of SUNBURST and target-profiling**
Sep 4 – Attackers start accessing SolarWinds*
Sep 12 – Attackers start injecting test code*
Nov 4 – Attackers stop injecting test code*
Feb 20 – Solorigate backdoor is compiled and deployed*
May – Estimated start of actual hands-on-keyboard attacks
Activation of TEARDROP**
Continued hands-on-keyboard activity**
Jun 4 – Attackers remove malware from SolarWinds build environment*
Dec 12 – Solorigate supply chain attack disclosed
2019
2020
2021
Sep
Oct
Nov
Dec
Jan
Feb
Mar
Apr
May
Jun
Jul
Aug
Sep
Oct
Nov
Dec
Jan


Attacker
Initial C2
Second C2
Cobalt Strike C2
ON-PREMISES
DEVICE
solarwinds.business layerhost.exe
SolarWinds.Orion.Core.BusinessLayer.dll (compromised)
Backdoor activates
Backdoor inspects environment
Backdoor gathers info
Backdoor connects to initial C2, sends gathered info
Cobalt Strike downloaded from a second C2
Remote control via Cobalt Strike Beacon
Hands-on-keyboard attack on premises

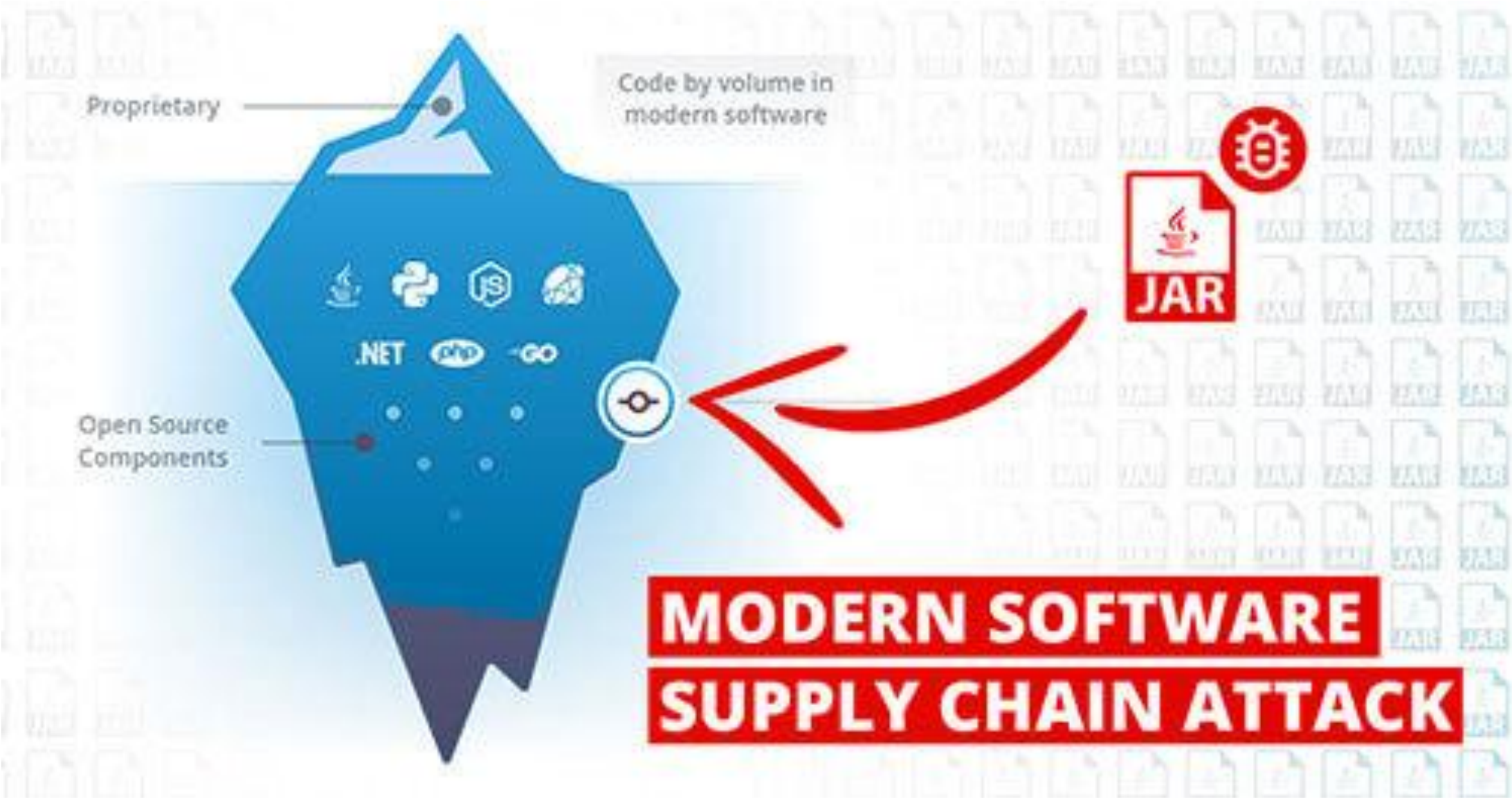
Cozy Bear

- Cozy Bear (aka APT29 aka CozyCar aka NOBELIUM aka CozyDuke aka YTTRIUM, etc.)
- Behavior is distinct to Fancy Bear, but targets consistent with cyber espionage motives of the Russian government
- Considered an APT (Advanced Persistent Threat) by most security firms


ADVERSARY SPACE
Two separate Russian espionage groups
NEUTRAL SPACE
VICTIM SPACE
APT29
1 Leverages
Operational Infrastructure
2 Pushes
Implant
3 Establishes encrypted communication with
4 Silently exfiltrates data
APT29 TRADECRAFT
• Powershell comand
• Scheduled execution
• Unique encryption keys
TARGETED SYSTEMS
APT28
1 Leverages
Operational Infrastructure
2 Deploys
X-Agent
3 Installs onto
4 Leverages
X-Tunnel
5 Enables remote execution
APT28 TRADECRAFT
• Remote execution
• File transmission
• Keylogging

Cozy Bear

- Known for installing multiple forms of malware on compromised machines so they can always take control again
- Also known for fastidiously covering its tracks
- Sunburst – backdoor and C&C; identifies antivirus/antimalware and other monitoring tools


Proprietary
Code by volume in modern software
.NET
GO
Open Source Components
JAR
MODERN SOFTWARE
SUPPLY CHAIN ATTACK

“The tradecraft was phenomenal. This was the craziest &@$*(@^ thing I'd ever seen.”

– Adam Meyers, SVP of Intelligence at Crowdstrike and lead of Forensics team hired by Solarwinds

Sophisticated Supply Chain Attack

- Cozy Bear didn’t change any source code
- They monitored compiling and injected their malware into the software while it was compiling

OUTCOMES

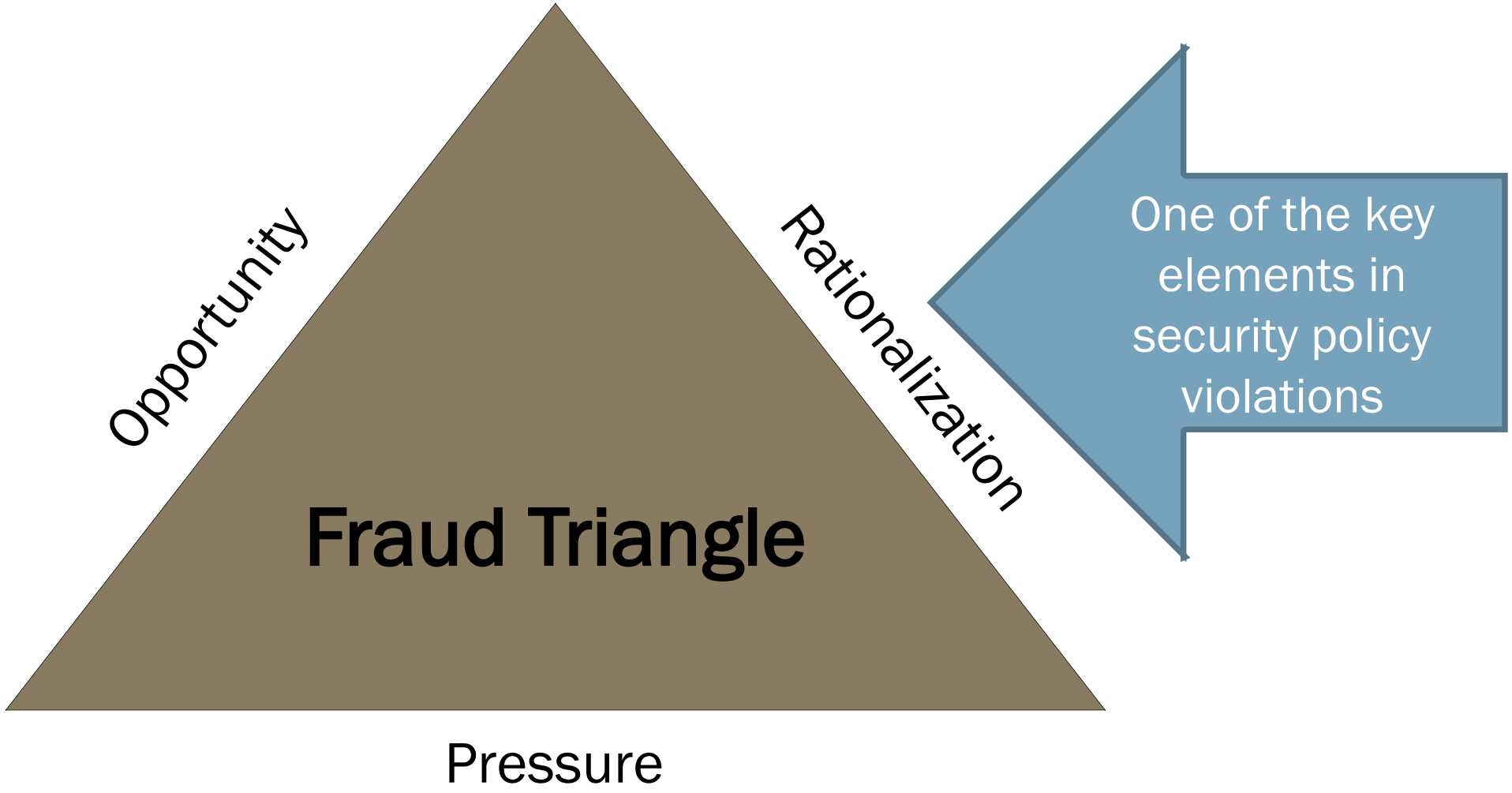
- Nearly 100 organizations compromised (that we know of) out of ~18,000 SolarWinds customers
  - *FireEye, Microsoft, US Justice Department, US State Department, NASA, NVIDIA, Intel, Cisco, and more*

- CISO Emergency Directive
  - *https://cyber.dhs.gov/ed/21-01/*

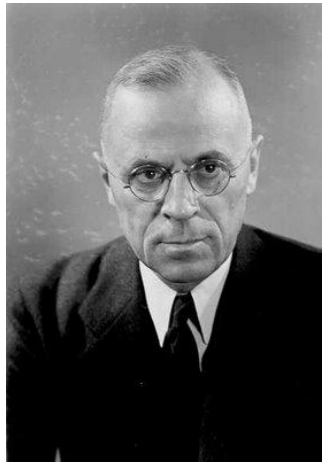
IF WE HAVE TIME

POLICIES & BEHAVIOR

Does the Fraud Triangle Apply to Security Behaviors?

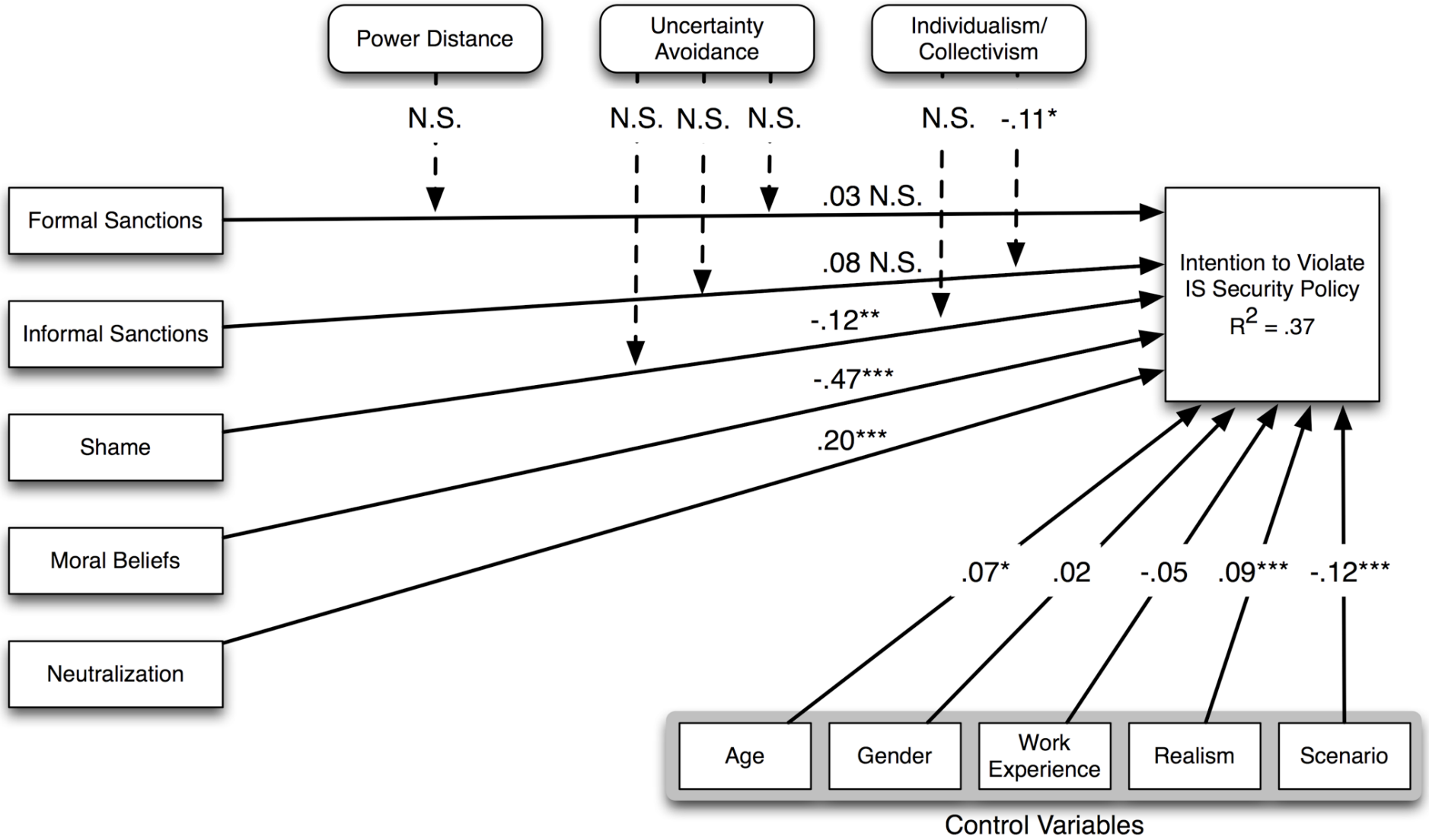


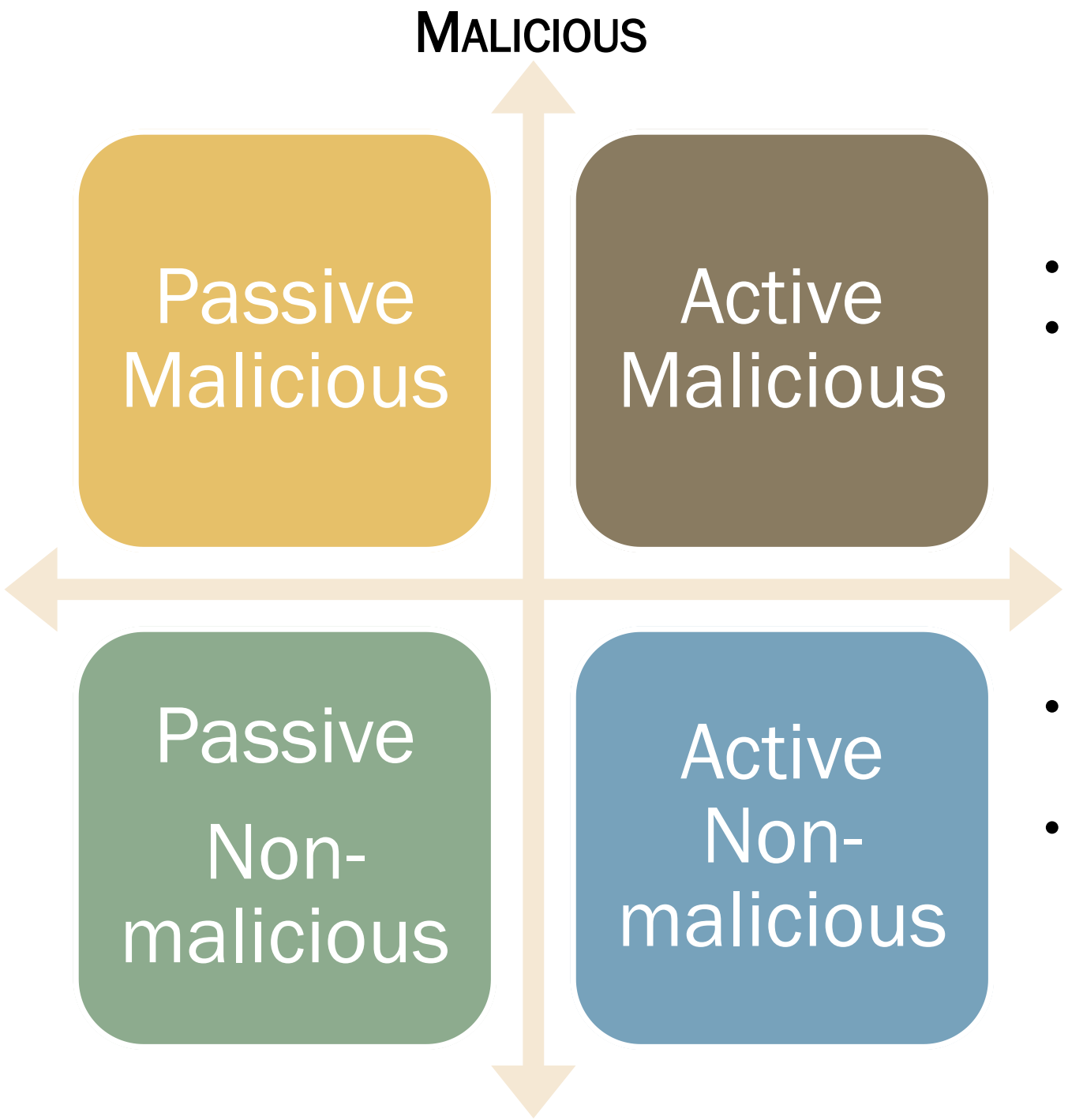
Techniques of Neutralization (Matza & Sykes)



- Denial of responsibility
  - *"Not my fault"*
- Denial of injury
  - *"No one got hurt"*
- Denial of the victim
  - *"They deserved it"*
- Condemnation of the condemners
  - *"You're a hypocrite and have done the same or worse"*
- Appeal to higher loyalties
  - *"Had to protect the family"*

FROM THE ACADEMIC RESEARCH (SIPONEN & VANCE)





- Not logging off
- Delaying patches or backups

- Fraud
- Sabotage

- Losing USB drive

- Choosing bad passwords
- Naively opening phishing emails

Policies and Training … What We Know

- They should target specific security behaviors
- Sanctions (punishments) tend not to be effective
- Focus on “neutralizing” the “neutralization techniques”